

Core Concepts — The Regulatory Landscape

Part 14 —  AI Compliance · 14-ai-compliance/notes/01-regulatory-landscape.md

Verified against primary and law-firm-tracker sources as of September 2026. This is the fastest-moving page in the whole repo. Treat every date as "true when checked" and re-check before you rely on it — see notes/03 [14-ai-compliance/notes/03-building-a-compliance-program.md] for exactly where to look.

1. Two philosophies, one problem

The EU regulates AI the way it regulates medical devices and machinery: a horizontal law, ex-ante risk tiers, conformity assessment before market entry. The US regulates AI the way it regulates most things: no single statute, existing sectoral regulators stretching existing law over AI, states filling gaps unevenly, and courts sorting out the rest years later. Neither is "ahead" — they're optimizing for different failure modes. The EU accepts slower deployment to get pre-market assurance; the US accepts patchier coverage to avoid a innovation-slowing federal bottleneck. You need fluency in both if you ship globally.

2. The EU AI Act — risk-based tiers

The AI Act (Regulation (EU) 2024/1689) sorts AI systems into four tiers by **risk to health, safety, and fundamental rights** — not by how advanced the technology is. A simple spam filter and a frontier LLM can both be "minimal risk"; a comparatively simple CV-screening script can be "high-risk." Classification is about *use*, not sophistication.

Tier 1 — Unacceptable risk (prohibited outright, Article 5)

A short list of practices banned in the EU regardless of accuracy or safeguards, because the Act treats them as incompatible with fundamental rights. In force since **2 February 2025**. Concretely:

- **Social scoring** by public authorities that evaluates people across unrelated contexts and leads to disproportionate detrimental treatment.
- **Subliminal or manipulative techniques** that materially distort behavior and cause harm.
- **Exploitation of vulnerabilities** (age, disability, socio-economic situation) to distort behavior.
- **Biometric categorization** inferring race, political opinion, union membership, religion, or sexual orientation from biometric data.
- **Untargeted scraping** of facial images from the internet or CCTV to build facial-recognition databases.
- **Emotion inference** in workplaces and schools (with narrow safety/medical exceptions).
- **Real-time remote biometric identification** in public spaces for law enforcement (narrow, judicially authorized exceptions for specific serious crimes).
- A carve-out for non-consensual intimate imagery/CSAM-adjacent systems was itself phased in later — verify current status before assuming full Article 5 coverage is live for every sub-clause.

If your use case is in this list, there is no compliance path — the fix is "don't build it," not "document it better."

Tier 2 — High-risk (Article 6, Annexes I and III)

Two routes into this tier:

- **Annex I** — AI that is a safety component of, or is itself, a product already regulated under EU product-safety law (medical devices, machinery, lifts, toys, radio equipment, aviation, cars).
- **Annex III** — AI used in eight listed sensitive domains regardless of what product it's embedded in: **biometrics; critical infrastructure; education (admissions, exam scoring, proctoring); employment (CV screening, promotion/termination decisions, worker monitoring); essential private/public services (credit scoring, insurance pricing, benefits eligibility, emergency dispatch); law enforcement; migration and border control; and the administration of justice and democratic processes.**

Concrete examples: a resume-screening tool that ranks candidates = high-risk (Annex III, employment). A credit-scoring model = high-risk (Annex III, essential services). An AI-enabled insulin pump's dosing algorithm = high-risk (Annex I, medical device). Article 6 also lets a provider argue a system is *not* high-risk despite matching an Annex III category if it only performs a narrow procedural task, improves a completed human activity, detects patterns without replacing human judgment, or does prep work for a task — document that reasoning if you rely on it, because it's exactly the kind of judgment call a regulator will ask you to justify.

Obligations for high-risk systems (Articles 9–17, deployer duties in Article 26) — this is the heavy lift of the whole Act:

Obligation	What it actually requires
Risk management system	A living process across the lifecycle, not a one-time form
Data governance	Training/validation/test data quality, relevance, representativeness checks
Technical documentation	Enough detail for an authority to assess compliance (Annex IV)
Record-keeping / logging	Automatic logs enabling traceability over the system's lifetime
Transparency to deployers	Instructions for use sufficient for a deployer to comply with <i>their</i> duties
Human oversight	Measures letting a human understand, monitor, and override the system — see Module 12's human-oversight design [12-ai-governance] for how you actually build this, not just document it
Accuracy, robustness, cybersecurity	Appropriate levels stated and tested, resilience to errors/attacks — this is exactly the testing surface Module 15 — AI Evaluation [15-ai-evals] covers; the Act tells you <i>that</i> you must measure it, evals tell you <i>how</i>
Conformity assessment	Self-assessment for most Annex III systems, or third-party via a notified body for a narrower set (notably some biometric systems); results in a CE mark and an EU database registration

Deployers (the organization *using* the system, not the vendor building it) have lighter but real duties: use it per instructions, ensure human oversight in practice, monitor for known/foreseeable risks, and for certain public-sector and high-impact private uses, conduct a **fundamental rights impact assessment**.

Tier 3 — Limited risk / transparency obligations (Article 50)

No pre-market assessment; instead you must **disclose**. Applies to: chatbots (users must be told they're talking to AI, unless obvious from context), emotion-recognition and biometric-categorization systems (inform the exposed person), and generative systems producing synthetic audio/image/video/text (mark outputs as AI-generated in a machine-readable, detectable way) and deepfakes specifically (clear disclosure). Concrete example: a customer-service chatbot with a "you're chatting with an AI assistant" disclosure sits here, not in Tier 2 — disclosure is the whole obligation, there's no conformity assessment.

Tier 4 — Minimal risk (everything else)

No obligations under the Act itself. A spam filter, an internal analytics dashboard, an AI-assisted code completion tool — most day-to-day AI usage lives here. The Act *encourages* voluntary codes of conduct for this tier but does not require them. Don't over-engineer compliance theater for a minimal-risk system; spend that budget on the high-risk ones.

The separate track: general-purpose AI (GPAI) models

This is structurally distinct from the four-tier system above — it regulates the **model**, not the **application**, and applies to providers of general-purpose models (think: foundation-model labs) rather than to everyone deploying AI. Verified: GPAI obligations (Chapter V) became applicable **2 August 2025**, with Commission enforcement beginning **2 August 2026**.

- **All GPAI providers:** maintain technical documentation, provide information to downstream integrators, have a copyright-compliance policy (respecting rights-holder opt-outs, e.g. under the EU's TDM exception), and publish a sufficiently detailed training-data summary.
- **GPAI models with "systemic risk":** models whose cumulative training compute exceeds 10^{25} FLOPs are presumptively systemic-risk (providers can rebut this with evidence). These carry extra duties: adversarial testing/red-teaming, incident reporting to the Commission, cybersecurity protections, and energy-efficiency reporting.
- The Commission published a voluntary **GPAI Code of Practice** (10 July 2025, covering transparency, copyright, and — for systemic-risk models — safety/security) that providers can adhere to as a way of demonstrating compliance; it is not itself binding law.

Why this two-track structure matters practically: if you fine-tune or wrap a frontier model into a resume-screener, you inherit high-risk *application* obligations under the risk-tier track, while the model provider separately carries GPAI obligations under the model track. Neither discharges the other — see Module 11's build-vs-buy discussion [11-llm-models] for how model choice interacts with this.

The timeline — verify before you plan around it

The Act entered into force 1 August 2024 with a long phase-in, then in 2026 the EU's "**Digital Omnibus on AI**" amended several deadlines. As last verified (September 2026):

Date	What applies	Status as of last check
2 Feb 2025	Prohibited practices (Article 5), AI literacy duties	In force
2 Aug 2025	GPAI obligations, governance bodies, penalty framework	In force
2 Dec 2026	Synthetic-content marking duty for pre-existing systems; some CSAM/NCII prohibition provisions	Deferred from Aug 2026 by the Digital Omnibus — verify
2 Aug 2026	Article 50 transparency duties (chatbot/deepfake disclosure) for new systems; Commission GPAI enforcement begins	In force on schedule
2 Dec 2027	High-risk obligations for Annex III (use-based) systems	Deferred 16 months from the original 2 Aug 2026 date by the Digital Omnibus (agreed May 2026, in force late July 2026) — verify this hasn't moved again
2 Aug 2027	GPAI compliance deadline for models already on the market; sandboxes operational	Scheduled
2 Aug 2028	High-risk obligations for Annex I (product-embedded) systems	Deferred 1 year from 2 Aug 2027 by the same Omnibus

The one-sentence version to internalize, not the dates themselves: prohibitions and GPAI rules are live now; the heavy high-risk application obligations were pushed back well past their original 2026 date, and the EU has shown it will amend deadlines under industry pressure — so "compliant with the version of the Act I read six months ago" is not a safe assumption. Confirm current status at artificialintelligenceact.eu/implementation-timeline or the [EU AI Act Service Desk](#) before any date-sensitive decision.

3. The US — a fragmented, fast-moving patchwork

There is no US federal AI-Act equivalent. What exists, layered:

Federal: influence without a single binding statute

- **NIST AI Risk Management Framework (AI RMF 1.0, Jan 2023)** — voluntary, but the most-referenced US framework; the FTC, CFPB, FDA, SEC, and EEOC all cite its Govern/Map/Measure/Manage structure in guidance. Already covered in depth in Module 12 [12-ai-governance] — this module treats it as the baseline your compliance program should map onto, not re-teaches it.

- **Executive orders** swing hard with administrations and do not bind private companies directly, but shape agency posture and federal procurement. As of September 2026, the operative one is **EO 14365 (December 2025)**, "Ensuring a National Policy Framework for Artificial Intelligence" — it directs a DOJ AI Litigation Task Force to challenge state AI laws as unconstitutional/preempted and threatens conditioning federal funding on states not enforcing "onerous" AI laws. **This is a live fight, not settled law:** state laws remain enforceable unless and until a court strikes them down, and the litigation was ongoing as of the last check. Do not assume any specific state law has been preempted without checking current case status.
- **FTC:** no AI-specific rulemaking; enforces existing Section 5 (unfair/deceptive practices) authority against AI-related harms — fake AI capability claims, "AI washing," dark patterns, and (per a **July 2026 policy statement**) deceptive suppression of accurate model outputs in favor of an undisclosed steered objective. The FTC's own stated posture in 2026 is enforcement against concrete bad actors, not speculative future harm — read that as "fraud and deception law applied to AI," not "an AI-specific rulebook."

State: the real action, and it moves constantly

No two states agree, and laws here are amended or delayed with unusual frequency — the case study is **Colorado's AI Act (SB 24-205)**: passed 2024 with a comprehensive risk-based framework and a February 2026 effective date; delayed to June 2026; then, days before that deadline, **rewritten by SB 189 (signed May 2026)** into a much narrower disclosure-and-transparency law, effective **1 January 2027**, that drops the original duty-of-care and impact-assessment requirements entirely. If you built a compliance program against the 2024 text, most of that work no longer maps to current law. Other states worth tracking (verify current text, don't assume the description below is still accurate): Illinois (AI-in-hiring disclosure), California (a cluster of narrower AI bills — deepfake disclosure, generative-AI training-data transparency, automated-decision rules under CCPA regulations), and Texas (a narrower, enforcement-light AI act). Treat any specific state-law claim in this module, or anywhere else, as needing a same-week re-check.

Sector regulators: AI slotted into rules that already existed

The more durable US pattern is existing sectoral law absorbing AI rather than new AI-specific law:

- **Financial services:** bank supervisors' model-risk-management guidance, not a new AI statute, governs AI-driven credit and risk models — see notes/02 [14-ai-compliance/notes/02-sectors-data-protection-and-standards.md] for the SR 11-7 → SR 26-2 detail and fair-lending implications.
- **Healthcare:** HIPAA governs the data; FDA governs AI/ML as a medical device — again, existing frameworks extended, detailed in notes/02.
- **Employment:** federal EEOC guidance treats AI hiring tools under existing Title VII disparate-impact theory; city/state laws (e.g., NYC) add specific audit mandates on top.

How to teach yourself to read this landscape rather than memorize a snapshot: ask, for any US AI question, "which existing law is this AI system now subject to, and has any state or agency layered an AI-specific rule on top?" That question ages better than any specific citation in this file.

4. Forward links

Idea here	Where it returns
High-risk human oversight requirement	Module 12 [12-ai-governance] — how you actually design and document it
Accuracy/robustness testing obligations	Module 15 [15-ai-evals] — the eval suites that produce the evidence
GPAI vs. application-level obligations	Module 11 [11-llm-models] — model choice and vendor due diligence
Technical documentation as shared evidence	notes/03 [14-ai-compliance/notes/03-building-a-compliance-program.md] and code/compliance_documentation_mapper.py [14-ai-compliance/code/compliance_documentation_mapper.py]
RAG/agent systems and personal data	notes/02 [14-ai-compliance/notes/02-sectors-data-protection-and-standards.md] and Module 08 [08-rag], Module 13 [13-ai-security]